

Literature Review

Aayuman Ghangurde
Purdue University

Sai Palaparthi
Purdue University

Rakib Ahsan
Purdue University

Zeke Ulrich
Purdue University

1 Related Work

1.1 Technical Report on a Virtual CTAP2 WebAuthn Authenticator

Summary: This technical report covers the development of the associated open source Virtual CTAP2 WebAuthn authenticator. In addition to a software only authenticator it also provides a proof of concept implementation of a Trusted Platform Module (TPM) based authenticator, with associated interfaces and libraries for using a TPM as the underlying credential store.

Shortcomings: This project wants several improvements we hope to make, including:

- the authors deliberately keep client-PIN verification outside the TPM (software ES256 provider), reasoning that the PIN is typed anyway so it "doesn't warrant" TPM protection. This is a waste of modern TPMs' built-in dictionary-attack prevention, which we can enable.
- their authenticator uses a flat key hierarchy with no dictionary-attack protection on the intermediate key. If we use passkey signing keys as children of an intermediate PIN key that has a lockout policy, then unlocking the PIN key makes them usable just as with Windows Hello and we have brute force protection against the PIN.
- the paper notes that their method of emulating a USB HID device is fragile. We can build the authenticator as a PAM module for extensibility.
- the authenticator supports only ES256, which we could expand to RSA and Ed25519.

1.2 A Novel High-Performance Implementation of CRYSTALS-Kyber with AI Accelerator

Summary: The authors implement a version of CRYSTALS-Kyber on the NVIDIA AI accelerator Tensor Core to to accelerate the polynomial multiplication phase and achieve considerable performance improvement, which they believe can generalize to other more lattice-based cryptographic schemes, and eventually homomorphic encryption.

Shortcomings: The generality of the proposed framework for module lattice based cryptography broadly is asserted but unsubstantiated. Additionally, the results come from a single RTX 3080 with Ampere and there's no testing across other Tensor Core generations or other AI accelerators (TPU, Apple Neural Engine, NPUs), despite the paper claiming its contribution as a general framework for AI-accelerator-based cryptography.

1.3 The State of Passkeys: Studying the Adoption and Security of Passkeys on the Web

Summary: The authors perform a comprehensive security evaluation of passkey implementation in websites. The authors identify lack of standardization and serious security issues in a majority of websites, including use of deprecated cryptographic algorithms and critical or high CVSS scores. The authors present `PASKEYS-RADAR` for tracking deployment of passkeys on the web, and `PASKEYS-ATTACKER` for exploiting security vulnerabilities on insecure sites.

Shortcomings: The authors acknowledge several limitations of their approach, including:

- *Overestimation of adoption rate:* the automated detection of passkey-enabled websites inevitably produces

false positives, which leads to an overestimation of the adoption.

- *Limited representativeness of the dataset:* the dataset is biased toward publicly accessible, consumer-facing services. Certain sectors, such as online banking, could not be systematically evaluated due to the lack of suitable test accounts.
- *Different authentication backends:* It is not possible to automatically determine whether multiple domains operated by the same provider (e.g., gmail.com and youtube.com) share a common authentication backend.

1.4 FIDO2, CTAP 2.1, and WebAuthn 2: Provable Security and Post-Quantum Instantiation

Summary: The authors formally analyze FIDO2's security with the CTAP 2.1 and WebAuthn 2 sub-protocols. The authors prove post-quantum security for FIDO2 under certain conditions and minor protocol extensions, and show a simple improvement for the downgrade resilience of FIDO2.

Shortcomings: Since the paper is an abstract proof of CTAP and WebAuthn, the authors do not model some of the new CTAP 2.1 features for enterprise customers, and do not make formal statements about the unlinkability of credentials or other detailed privacy statements. Thus, the implementation of these standards may have unaddressed vulnerabilities.

References